CYBER THREAT INTELLIGENCE REPORT

CRITICAL

사이버 무기 공급망의 붕괴와 국가 안보 위협

Coruna iOS Exploit Kit 사례 분석 및 제로데이 거래 생태계 연구

— 한국 정부 사이버 안보 정책에 대한 시사점과 대응 전략 —

HoKwang Kim, gameworker@gmail.com

https://github.com/gameworkerkim/

항목	내용
분류	위협 인텔리전스 / 정책 분석 리포트
위협 수준	CRITICAL (긴급 대응 필요)
분석 대상	Coruna iOS Exploit Kit (CVE-2024-23222)
영향 범위	iOS 13.0 ~ 17.2.1 / 한국 정부·공공기관 포함
작성 목적	방어·연구·정책 수립 — 교육 목적 공개
작성일	2026년 3월 20일
분류 기준	OSINT 기반 공개 위협 인텔리전스

목 차

1. 개요 (Executive Summary)

2. Coruna iOS Exploit Kit 기술 분석

3. 사이버 무기 공급망: 개발에서 범죄화까지

4. 제로데이 취약점 거래 생태계 — 구조, 플랫폼, 거래 흔적

5. 취약점 확산 속도의 가속화: VBScript에서 WebKit까지

6. 한국 정부 사이버 안보 현황과 위협 분석

7. 문제 진단: 현행 대응 체계의 한계

8. 대안 제시: 국제 협력·커뮤니티·AI 기반 방어 전략

9. 결론

참고문헌

1. 개요 (Executive Summary)

사이버 무기는 더 이상 국가의 전유물이 아니다. 본 리포트는 미국 방위산업체 Trenchant(L3Harris 자회사)에서 개발된 것으로 강하게 의심되는 Coruna iOS Exploit Kit이 내부자 유출을 통해 러시아 사이버 무기 브로커에게 판매되고, 이후 중국 금전 목적 해킹 집단에까지 전파된 과정을 분석한다.

이 사례는 세 가지 핵심 패러다임 전환을 상징한다.

첫째, 국가급 사이버 전략 자산의 민간화(Democratization of Cyber Weapons)가 이미 현실화되었다.

둘째, 제로데이 취약점의 국가 독점 사용 기간이 과거 수년에서 수개월로 급격히 단축되었다.

셋째, 한국을 포함한 아시아 지역 정부기관이 이러한 고도화된 공격의 직접적 표적이 되고 있다.

> *핵심 메시지: 오늘의 국가 전략 자산이 내일의 사이버 범죄 도구가 된다. 한국 정부는 실시간 국제 협력, AI 기반 모니터링, 그리고 제도적 대응 체계의 전면 재설계가 필요한 시점에 있다.*

2. Coruna iOS Exploit Kit 기술 분석

2.1 개요 및 CVE 분석

Coruna는 iOS 13.0~17.2.1을 표적으로 하는 고도의 상업적 원격 익스플로잇 킷(Exploit Kit)으로, 사용자의 어떠한 조작 없이 악성 웹페이지 방문만으로 기기를 완전히 장악하는 '원클릭(1-Click)' 공격 체인을 구현한다. 핵심 취약점은 CVE-2024-23222로, WebKit의 JavaScriptCore(JSC) 엔진에서 발생하는 타입 혼란(Type Confusion) 취약점이다.

항목	내용
CVE	CVE-2024-23222
영향 범위	iOS 13.0 ~ 17.2.1 (전 세계 수억 기기)
패치 버전	iOS 17.3+ (2024년 1월 패치)
공격 유형	1-Click WebKit RCE → 완전 기기 장악
개발 의심 주체	Trenchant / L3Harris (미국 방위산업체)
실제 악용 사례	우크라이나 정부 표적 공격, 암호화폐 피싱

2.2 8 단계 공격 체인

Coruna의 공격 흐름은 다음 8개 단계로 구성된다:

- Stage 0 — group_loader.html: 공격 진입점, HTML 래퍼 및 모듈 오케스트레이션
- Stage 1 — platform_module.js: iOS 버전, 기기 모델, 잠금 모드 감지
- Stage 2 — stage1_wasm_primitives.js: CVE-2024-23222 타입 혼란으로 arbitrary read/write 달성
- Stage 3 — stage2_pac_bypass.js: Intl.Segmenter vtable 오염을 통한 PAC(포인터 인증 코드) 우회
- Stage 4 — stage3_sandbox_escape.js: Mach-O 빌더 + ARM64 가젯 체인으로 샌드박스 탈출 (~147KB)
- Stage 5 — stage4_payload_stub.js: 암호화 페이로드 전달 스텁
- Stage 6 — stage5_main_payload.js: PLASMAGRID 스테이저 (AES 암호화, ~292KB)

- Stage 7 — stage6_binary_blob.bin: PGP 암호화 최종 바이너리 (~227KB)

2.3 C2 인프라 및 침해지표(IOC)

공개 분석을 통해 확인된 침해지표(Indicators of Compromise)는 다음과 같다:

지표 유형	값	용도
C2 도메인	8df7.cc	IP 동기화 텔레메트리
API 엔드포인트	https://8df7.cc/api/ip-sync/sync	피해자 IP 수집
Google Analytics	G-LKHD0572ES	방문자 추적 및 캠페인 관리
캠페인 ID	CHMKNI9DW334E60711	공격 캠페인 식별자
모듈 솔트	cecd08aa6ff548c2	SHA-256 모듈 파일명 해싱 키
피싱 벡터	가짜 암호화폐 거래소 사이트	UNC6691 초기 접근 수단

> *주요 탈취 대상 데이터: 암호화폐 지갑 복구 구문(Seed Phrase), 사진 앱 내 QR 코드, Apple Notes 내 민감정보, iCloud Keychain 자격증명, 기기 핑거프린트*

3. 사이버 무기 공급망 - 개발에서 범죄화까지

3.1 공급망 흐름도

단계	시기	행위자	역할 / 표적
개발	~2024	Trenchant / L3Harris (미국)	정부·민간 감시업체 대상 제한 공급
내부자 유출	2024~2025	피터 윌리엄스 (전 직원)	Operation Zero에 익스플로잇 킷 판매
중개 유통	2025 상반기	Operation Zero (러시아 브로커)	사이버 무기 마켓플레이스 유통
국가급 사용	2025년 여름	UNC6353 (러시아 연계)	우크라이나 정부·군사 인사 표적 공격
범죄 전용	2025년 말	UNC6691 (중국 기반 금전목적)	가짜 암호화폐 사이트 피싱·자산 탈취

3.2 Operation Zero — 러시아 기반 사이버 무기 브로커

Operation Zero는 국가급 제로데이 취약점 및 익스플로잇 킷의 매입·재판매를 전문으로 하는 러시아 기반 사이버 무기 중개 마켓플레이스다. 위협 인텔리전스 연구기관의 분석에 따르면 이 플랫폼은 구매자 신원 검증 없이 완화된 기준으로 거래를 중개하며, 익스플로잇의 '라이선스' 모델(일회성 vs 구독형)로 운영된다.

국가 행위자와 사이버 범죄 집단이 혼합된 고객 구성을 가지며, Telegram 채널과 다크웹 기반 에스크로 시스템을 통해 거래를 진행하는 것으로 보고되었다. Recorded Future의 분석에 따르면, Operation Zero는 iOS·Android 제로데이에 대해 수백만 달러 수준의 가격을 제시한 바 있다.

> *전략적 시사점: Operation Zero 같은 중개자의 존재는 '사이버 무기 민간화(Democratization of Cyber Weapons)'가 이미 구조화된 현실임을 증명한다. 충분한 자금력을 갖춘 집단이라면 누구나 국가급 사이버 무기를 구매 가능한 상품으로 접근할 수 있게 되었다.*

4. 제로데이 취약점 거래 생태계 — 구조, 플랫폼, 거래 흔적

4.1 제로데이 취약점 시장의 계층 구조

제로데이 취약점 거래 시장은 크게 세 계층으로 구분된다. 합법적 취약점 공개 보상 프로그램(Bounty Program)인 화이트 마켓, 정부 계약 기반의 민간 감시업체들이 참여하는 그레이 마켓, 그리고 다크웹·텔레그램 기반의 블랙 마켓이다. Coruna 사례는 그레이 마켓에서 블랙 마켓으로의 전환을 보여주는 대표적 사례다.

시장 구분	특징	대표 사례
화이트 마켓	합법적 버그 바운티, 벤더 공개 패치	HackerOne, Bugcrowd, Apple Security Bounty
그레이 마켓	정부·민간 감시업체 대상 비공개 거래	Zerodium, Crowdfense, Exodus Intelligence
블랙 마켓	다크웹·Telegram 기반 익명 거래, 규제 없음	Operation Zero, 다크웹 포럼

4.2 유사 해킹 툴 판매 흐름 분석

Coruna와 유사한 고급 모바일 익스플로잇의 거래 흐름은 일반적으로 다음 패턴을 따른다. 연구자 또는 내부자가 취약점을 발견하면 Telegram 채널이나 프라이빗 포럼을 통해 브로커에게 접근한다. 브로커는 구매자를 탐색하고 암호화폐 기반 에스크로 거래를 통해 대금을 결제한다. 최종 구매자는 국가 행위자, 민간 감시업체, 또는 자금력이 있는 사이버 범죄 집단이다.

4.3 암호화폐 기반 결제 구조와 거래 추적

사이버 무기 거래의 주요 결제 수단으로 비트코인(BTC)이 선호되는 것은 다음 이유에서다.

첫째, 탈중앙화 구조로 은행 동결·제재 회피가 가능하다.

둘째, CoinJoin, Wasabi Wallet, Samourai Wallet 등 믹싱 기법을 통해 거래 흔적 추적을 어렵게 만들 수 있다.

셋째, P2P 특성으로 중개기관 없이 국경을 초월한 즉시 결제가 가능하다.

그러나 Chainalysis 등 블록체인 분석 기업의 연구에 따르면 암호화폐 거래는 완전히 익명화

되지 않는다. 공개 블록체인의 특성상 충분한 추적 기술과 온체인 분석 역량을 갖춘 기관은 자금 흐름의 상당 부분을 재구성할 수 있다.

> *보안 연구 기관 Chainalysis의 2024년 보고서에 따르면, 사이버 범죄와 연관된 암호화폐 주소에서 탐지된 불법 거래 규모는 2023년 기준 약 240억 달러에 달하며, 이 중 상당 부분이 랜섬웨어 및 사이버 무기 거래와 연관된 것으로 분석되었다. 믹싱 서비스 사용에도 불구하고 전체 불법 거래의 약 40%는 거래소 KYC(고객 확인 절차)를 통해 식별 가능한 것으로 나타났다.*

4.4 알려진 사이버 무기 거래 인프라 (연구 목적 공개 IOC)

위협 인텔리전스 연구자들이 공개 보고서를 통해 식별한 사이버 무기 거래 관련 인프라는 다음과 같다. 이 정보는 방어 및 탐지 목적으로만 활용되어야 하며, 원본 연구 보고서에서 확인 가능하다:

- Telegram 채널: 다수의 비공개 채널이 제로데이 취약점 입찰에 활용됨 (Recorded Future, 2024 보고서)
- 에스크로 서비스: Monero(XMR) 기반 다크웹 에스크로 플랫폼 — USDT·BTC 혼용
- 브로커 네트워크: Zerodium(합법), Operation Zero, 및 다수의 미확인 러시아·동유럽 기반 브로커
- 지불 패턴: 거래당 평균 수십만~수백만 달러 규모, BTC → XMR 변환 후 최종 수령 패턴 다수 관찰

5. 취약점 확산 속도의 가속화: VBScript 에서 WebKit 까지

5.1 역사적 맥락: 국가 독점 시대의 종언

과거에는 특정 국가가 발견한 제로데이 취약점이 수년간 해당 국가의 독점적 사이버 무기로 사용될 수 있었다. 대표적 사례가 VBScript(Visual Basic Script) 취약점이다. 마이크로소프트 인터넷 익스플로러 및 윈도우 기반 VBScript 엔진의 취약점들은 2012~2016년경 특정 국가

사이버 작전에서 발견·활용되기 시작했으나, 공개적으로 알려지기까지 3~5년의 시간이 소요되었다.

이처럼 제로데이 취약점의 '수명(shelf life)'이 길었던 이유는 인터넷의 낮은 연결성, 사이버 보안 정보 공유 인프라의 부재, 그리고 악성코드 분석 기술의 한계 때문이었다. NSA의 EternalBlue 취약점 역시 개발·운용 후 수년이 지난 2017년에야 Shadow Brokers에 의해 유출·공개되었다.

취약점/도구	최초 활용 추정	공개/유출 시점	독점 기간	비고
VBScript IE 취약점	~2012	~2016~2017	약 4~5년	특정 국가 APT 전용 활용
Stuxnet (CVE-2010-2568)	~2007~2008	2010년	약 2~3년	이란 핵시설 표적
EternalBlue (MS17-010)	~2012~2013	2017년 (Shadow Brokers)	약 4~5년	WannaCry 악용
CVE-2021-30860 (FORCEDENTRY)	~2020	2021년 (CitizenLab)	약 1~2년	Pegasus 사용
CVE-2024-23222 (Coruna)	~2023	2024~2025년	약 1년 미만	민간 범죄 조직까지 전파

5.2 확산 가속화의 메커니즘

제로데이 취약점의 국가 독점 기간이 급격히 단축된 배경에는 구조적 요인이 존재한다. 우선 사이버 무기 브로커 시장의 성숙화로, Operation Zero 같은 전문 중개 플랫폼이 제로데이 유통을 구조화·가속화하고 있다. 다음으로 내부자 위협의 증가다. Coruna의 피터 윌리엄스 사례처럼 방산업체 내부자에 의한 의도적 유출이 현실화되었다.

또한 오픈소스 위협 인텔리전스(OSINT)의 발전으로 CitizenLab, Mandiant, Kaspersky, Google Project Zero 등의 글로벌 연구기관이 국가급 악성코드를 신속히 역분석·공개하고 있다. 아울러 취약점의 '재발견' 현상도 나타난다. 한 국가가 발견한 취약점을 다른 국가나 독립 연구자가 독립적으로 발견하는 빈도가 증가하고 있으며, 이는 독점 기간을 구조적으로 단축시킨다.

> *Rand Corporation의 연구(2017)에 따르면 제로데이 취약점의 평균 수명은 약 6.9년이었으나, Symantec·ESET 등의 최신 분석은 고급 모바일 제로데이의 경우 현재 수명이 1~2년 이하로 급격히 단축되었음을 시사한다. 국가 독점 사용 기간은 더욱 짧아져 수개월 수준으로 접어들었다.*

5.3 함의: 방어자의 대응 시간 압박

취약점 확산이 가속화됨에 따라 방어자(Defender)가 패치를 배포하고 시스템을 보호할 수 있는 시간이 현저히 줄어들었다. 특히 한국처럼 정부·공공기관의 레거시 시스템 비율이 높고, 패치 적용 속도가 상대적으로 느린 환경에서는 이 문제가 더욱 심각하게 작용한다. VBScript 취약점이 수년간 특정 국가에서만 사용되었던 것과 달리, 오늘날의 고급 모바일 익스플로잇은 개발된 지 수개월 내에 범죄 집단의 도구로 전락할 수 있다.

6. 한국 정부 사이버 안보 현황과 위협 분석

6.1 한국을 표적으로 한 주요 사이버 공격 현황

한국은 지정학적 위치와 고도의 디지털화된 경제·행정 인프라로 인해 국가 배후 사이버 공격의 주요 표적이 되고 있다. 한국인터넷진흥원(KISA) 및 국가정보원 자료에 따르면, 한국 정부 기관 및 공공 인프라를 겨냥한 사이버 공격은 매년 증가 추세다.

연도	주요 사건	배후 추정	피해 규모
2009	7·7 DDoS 공격	북한 연계 추정	청와대·국방부 등 주요 사이트 마비
2013	3·20 사이버 테러	북한 Lazarus	방송·금융기관 PC 4만 8천여 대 파괴
2016	국방망 해킹 사건	북한 추정	작전계획 5015 등 국방 기밀 유출 의혹
2021	한국원자력연구원 해킹	Kimsuky (북한)	내부 시스템 무단 접근
2022~2024	APT 지속 공격	북한·중국 복합	정부·방산·연구기관 지속 침투

6.2 한국 정부 사이버 안보 구조의 취약점

현행 한국의 사이버 안보 대응 체계는 다음과 같은 구조적 취약점을 내포하고 있다:

- 부처 분산형 대응 체계: 국가정보원, 과학기술정보통신부, 국방부, 경찰청 등 다수 기관의 분산된 역할로 실시간 정보 공유와 통합 대응이 지연됨
- 레거시 시스템 의존도: 정부 및 공공기관의 구형 운영체제·소프트웨어 사용 비율이 높아 패치 관리의 어려움이 존재함
- 모바일 기기 보안 정책 미비: Coruna 와 같은 iOS 익스플로잇에 대한 정부 공무원 모바일 기기 보안 정책이 체계적으로 정비되지 않음
- 국제 위협 인텔리전스 공유 제한: 한국은 Five Eyes 등 주요 사이버 안보 동맹에서 제외되어 있어 실시간 위협 인텔리전스 공유 접근성이 제한됨
- 전문 인력 부족: 한국인터넷진흥원 등 기관의 사이버 위협 분석 전문 인력이 위협 규모 대비 부족한 것으로 평가됨

6.3 현 위협 시나리오: 한국이 직면한 리스크

Coruna 유형의 iOS 익스플로잇이 한국 정부 표적에 활용될 경우의 위험 시나리오를 분석하면 다음과 같다. 고급 iOS 익스플로잇이 Operation Zero 같은 브로커를 통해 한국의 지정학적 경쟁 세력에게 유입될 경우, 정부 고위 공직자의 모바일 기기를 통해 외교·군사 기밀이 유출될 수 있다.

특히 한국은 미국·북한·중국·러시아 등 복수의 국가 배후 사이버 행위자로부터 동시에 위협을 받는 유일한 국가 중 하나다. UNC6353(러시아 연계)이 우크라이나 정부 인사를 표적으로 삼았듯, 유사한 역량을 가진 집단이 한국 정부 인사를 표적으로 할 가능성은 충분히 현실적이다.

> *집중 모니터링 권고: 한국 정부는 Coruna 유형의 고급 모바일 익스플로잇에 대한 위협 인텔리전스 모니터링을 현재 대비 대폭 강화해야 한다. 특히 외교부, 국방부, 국가정보원, 핵심 방산업체 임직원의 모바일 기기에 대한 Zero-Trust 보안 아키텍처 도입이 시급하다.*

7. 문제 진단: 현행 대응 체계의 한계

7.1 국가 수준의 대응 공백

현행 글로벌 사이버 안보 거버넌스 체계는 사이버 무기의 공급망 오염에 대한 대응이 근본적으로 미흡하다. 무기수출통제 협약(Wassenaar Arrangement)이 사이버 무기에 적용되지만, 내부자 유출이나 다크웹 기반 거래는 규제 사각지대에 놓여 있다. 이러한 상황은 개별 국가의 방어 노력만으로는 해결이 불가능한 구조적 문제를 만들어낸다.

7.2 한국 특유의 대응 한계

한국의 경우 세 가지 고유한 문제가 복합적으로 작용한다. 첫째, 정보 공유 체계의 파편화다. 침해사고 정보가 기관 간 실시간으로 공유되지 않아 유사 공격의 반복 피해가 발생한다. 둘째, 위협 인텔리전스의 수동적 수집이다. 현재 주로 사후 분석에 의존하며, 능동적 위협 헌팅(Threat Hunting) 역량이 부족하다. 셋째, 국제 협력 네트워크의 제한성이다. Coruna 사례에서 드러난 것처럼 사이버 위협이 미국에서 러시아를 거쳐 중국으로, 다시 전 세계로 확산되는 다국적 공급망 구조에 대한 대응이 부족하다.

8. 대안 제시- 국제 협력·커뮤니티·AI 기반 방어 전략

사이버 무기 공급망의 붕괴와 취약점 확산 가속화에 대응하기 위해 한국은 다음 세 가지 축의 전략적 전환이 필요하다.

8.1 각국 보안 그룹과의 협력 강화

8.1.1 국제 사이버 안보 협력 체계 확대

한국은 Five Eyes(미국·영국·캐나다·호주·뉴질랜드)와의 위협 인텔리전스 공유 협력을 현재보다 대폭 강화해야 한다. 특히 미국 CISA(사이버보안·인프라보안청), 영국 NCSC, 독일 BSI 등과의 양자 정보 공유 협정을 체결하고, NATO 사이버방위협력센터(CCDCOE)와의 협력을 확대해야 한다.

Coruna 사례처럼 미국산 사이버 무기가 러시아·중국을 거쳐 한국에 위협이 되는 구조에서, 미국 사이버 사령부 및 NSA/CISA와의 실시간 정보 공유 체계 구축은 더 이상 선택이 아닌 필수다.

협력 기관	협력 내용	기대 효과
미국 CISA	제로데이 취약점 조기 경보, IOC 공유	공격 인지 시간 수개월 단축
영국 NCSC	APT 캠페인 분석 공유	한국 표적 공격 사전 탐지
NATO CCDCOE	사이버 훈련·전략 연구 협력	방어 역량 국제 수준 제고
Interpol Cybercrime	사이버 범죄 공조 수사	Operation Zero 유형 브로커 추적
FIRST (글로벌 CERT)	침해사고 공유 및 대응 조율	사이버 무기 확산 조기 차단

8.2 국가 간 실시간 위협 커뮤니티 확대

8.2.1 실시간 정보 공유 플랫폼 구축

현재 국내 사이버 위협 정보 공유는 KISA의 C-TAS(사이버위협정보공유시스템)를 중심으로 이루어지나, 국제 실시간 공유 역량은 제한적이다. MITRE ATT&CK 프레임워크와 STIX/TAXII 표준 기반의 자동화된 국제 위협 인텔리전스 공유 플랫폼 구축이 필요하다.

아울러 민간-정부 협력 모델 강화가 시급하다. 삼성, LG, 카카오, 네이버 등 국내 대형 기술기업의 보안 위협 인텔리전스를 정부와 실시간으로 공유하는 민관 공동 대응 체계를 구축해야 한다. 민간기업은 종종 정부보다 먼저 신규 공격 벡터를 탐지한다.

> *ENISA(유럽 사이버 안보청)의 2023년 연구에 따르면, 실시간 위협 인텔리전스 공유 체계를 갖춘 국가·기관은 그렇지 않은 경우 대비 침해사고 탐지 시간을 평균 60% 단축하고, 피해 규모를 40% 이상 감소시킨 것으로 나타났다.*

8.3 인공지능 기반 사이버 보안 모니터링

8.3.1 AI 위협 탐지 시스템 도입

Coruna 같은 고도로 난독화된 멀티스테이지 익스플로잇은 기존 시그니처 기반 탐지 시스템으로는 사실상 탐지 불가능하다. AI·머신러닝 기반 이상 행동 탐지(UEBA: User and Entity Behavior Analytics) 시스템은 공격 코드의 패턴이 아닌 행동 이상을 탐지함으로써 제로데이 공격에도 대응할 수 있다.

구체적으로 다음 AI 기반 도구들의 도입을 권고한다.

- AI 기반 모바일 위협 방어(MTD: Mobile Threat Defense): Lookout, Zimperium 등의 솔루션은 디바이스 레벨에서 익스플로잇 행동을 실시간 탐지
- 그래프 신경망 기반 C2 통신 탐지: DNS·네트워크 트래픽의 비정상 패턴을 그래프 분석으로 탐지하여 Coruna C2(8df7.cc 유형) 조기 식별
- LLM 기반 위협 인텔리전스 분석: 대용량 OSINT 데이터에서 새로운 위협 패턴을 자동 추출·분류
- 취약점 예측 모델: 코드 변경 이력, 패치 패턴, CVE 데이터를 학습하여 제로데이 발생 가능성이 높은 코드 영역 사전 식별

8.3.2 한국 정부 AI 보안 모니터링 시스템 로드맵

단계	기간	핵심 과제	기대 성과
1단계 — 기반 구축	1~2년	STIX/TAXII 기반 국제 CTI 연동, AI 탐지 파일럿 구축	탐지 시간 30% 단축
2단계 — 확장	2~3년	전 정부부처 AI 탐지 시스템 배포, 민관 공유 플랫폼 구축	커버리지 80% 이상
3단계 — 완성	3~5년	자율 위협 헌팅, 국제 실시간 공유 완성, AI 정책 대응 통합	선진국 수준 대응 체계

9. 결론

Coruna iOS Exploit Kit 사례는 21세기 사이버 안보 위협의 복잡성을 압축적으로 드러낸다. 미국 방위산업체에서 탄생한 정밀 해킹 도구가 내부자 유출, 러시아 브로커 중개, 중국 사이버 범죄 집단 활용을 거쳐 일반 시민의 암호화폐 탈취에 사용되기까지의 과정은 사이버 무기 공급망이 이미 심각하게 오염되어 있음을 보여준다.

특히 VBScript 취약점이 수년간 특정 국가에서만 사용되었던 것과 달리, 오늘날의 제로데이 취약점은 개발 후 수개월 만에 범죄 집단의 도구로 전락하는 수준으로 확산 속도가 가속화되었다. 한국은 이 위협의 직접적 표적이다.

이 문제를 해결하기 위해서는 한국 정부의 독자적 노력을 넘어서는 구조적 대응이 필요하다. 각국 보안 그룹과의 협력 강화, 국가 간 실시간 위협 인텔리전스 커뮤니티 확대, 그리고 AI 기반 사이버 모니터링 시스템의 조속한 도입이 그 핵심이다. 이는 선택의 문제가 아니라 국가 안보의 근본적 과제다.

> *최종 권고: 한국 정부는 사이버 안보 예산과 인력을 현재 수준에서 최소 3배 이상 확대하고, 국제 협력·AI 도입·실시간 커뮤니티 구축의 세 축을 동시에 추진하는 '사이버 안보 뉴딜'에 나서야 한다. Coruna는 경고였다. 다음은 더 정교하고 더 빠를 것이다.*

참고문헌

I. 기술 분석 및 위협 인텔리전스

[1] Tran, D. (2024). coruna_analysis: Technical analysis of Coruna iOS exploit kit. GitHub Repository. https://github.com/34306/coruna_analysis

[2] CVE-2024-23222 Detail. (2024). National Vulnerability Database. https://nvd.nist.gov/vuln/detail/CVE-2024-23222

[3] Apple Security Advisory. (2024). About the security content of iOS 17.3 and iPadOS 17.3. Apple Product Security.

[4] Mandiant Threat Intelligence. (2025). UNC6353 and the Russian Cyber Weapon Supply Chain: Analysis of Nation-State Exploitation Patterns. Google Cloud / Mandiant.

[5] Recorded Future. (2024). Inside Operation Zero: The Broker of Nation-State Zero-Day Exploits. Recorded Future Intelligence Cloud.

[6] Kaspersky Global Research & Analysis Team. (2024). From State Secrets to Cybercrime Tools: The Exploit Leak Economy. Kaspersky Securelist.

II. 암호화폐 및 거래 추적

[7] Chainalysis. (2024). The Chainalysis 2024 Crypto Crime Report. Chainalysis Inc. https://go.chainalysis.com/crypto-crime-2024

[8] Chainalysis. (2025). Cryptocurrency and Cyber Weapons: 2025 Annual Report on Illicit Crypto Flows. Chainalysis Inc.

[9] Europol. (2024). Internet Organised Crime Threat Assessment (IOCTA) 2024. European Union Agency for Law Enforcement Cooperation.

III. 제로데이 취약점 거래 생태계

[10] Ablon, L., & Bogart, A. (2017). Zero Days, Thousands of Nights: The Life and Times of Zero-Day Vulnerabilities and Their Exploits. RAND Corporation. https://doi.org/10.7249/RR1751

[11] Frei, S., May, M., Fiedler, U., & Plattner, B. (2006). Large-Scale Vulnerability Analysis. ACM Workshop on Large-Scale Attack Defense (LSAD). doi:10.1145/1162549.1162554

[12] Herley, C., & Florêncio, D. (2010). Nobody Sells Gold for the Price of Silver: Dishonesty, Uncertainty and the Underground Economy. In Economics of Information Security and Privacy, Springer.

[13] Bilge, L., & Dumitras, T. (2012). Before We Knew It: An Empirical Study of Zero-Day Attacks In The Real World. ACM CCS 2012. doi:10.1145/2382196.2382284

IV. 내부자 위협 및 사이버 무기 민간화

[14] Insider Threat Task Force. (2022). Insider Threat Mitigation Guide. U.S. Cybersecurity and Infrastructure Security Agency (CISA).

[15] Scott-Railton, J., Marczak, B., Razzak, B. A., Crete-Nishihata, M., & Deibert, R. (2021). Pegasus vs Predator: Dissident's Doubly-Infected iPhone Reveals Cytrox Mercenary Spyware. The Citizen Lab, University of Toronto.

[16] Deibert, R. J. (2015). Cyberspace Under Siege. Journal of Democracy, 26(3), 64–78. doi:10.1353/jod.2015.0051

V. AI 기반 사이버 보안 및 국제 협력

[17] ENISA. (2023). Threat Intelligence and Sharing: Benefits and Challenges for the EU Cybersecurity Ecosystem. European Union Agency for Cybersecurity.

[18] Lin, H., & Smeets, M. (2023). The Emerging Norms on Offensive Cyber Operations. Journal of Conflict & Security Law, 28(1), 1–28. doi:10.1093/jcsl/krad002

[19] Shu, X., Yuen, K. L., Gurulian, I., Lee, R. B., & Li, K. (2020). Threat Intelligence-Driven Dynamic Access Control for Industrial IoT. IEEE Transactions on Industrial Informatics. doi:10.1109/TII.2020.2975341

[20] Mirsky, Y., Demontis, A., Kotak, J., Shankar, R., Gelinas, D., & Elovici, Y. (2023). The Threat of Offensive AI to Organizations. Computers & Security, 124, 103032. doi:10.1016/j.cose.2022.103032

VI. 한국 사이버 안보

[21] Korea Internet & Security Agency (KISA). (2024). 2024 Korea Cybersecurity Report. Ministry of Science and ICT, Republic of Korea.

[22] National Intelligence Service (NIS). (2023). 2023 Cyber Threat Trend Report. National Intelligence Service, Republic of Korea.

[23] Kim, J., & Park, S. (2023). Challenges and Strategies for South Korea's Cybersecurity Policy in the Era of Digital Transformation. Korean Journal of International Studies, 21(2), 135–162.

[24] Sanger, D. E., & Markoff, J. (2024). Cyber Weapons and the New Rules of War. New York Times / Stanford Internet Observatory.

본 리포트는 공개된 OSINT 자료 및 위협 인텔리전스 보고서 기반으로 작성된 교육·방어 목적의 보안 분석 문서입니다.